

Framework di Cyber Deception & Anomaly Detection - File di Contesto

Tesi

1. Visione Generale

Il framework è un sistema di **Cyber Deception & Anomaly Detection (WAAP)** progettato per posizionarsi dietro un WAF perimetrale (es. Google Cloud Armor).

Obiettivo: Rilevare minacce Zero-Day e Account Takeover (ATO) tramite architettura ibrida IA + Trappole attive.

2. Mappa Architetture (Modello C4)

Livello 2: Container

- **Reverse Proxy [Go]:** Core online, routing e iniezione Honey-URL.
- **Servizio Inferenza IA [Python/FastAPI]:** Modello Isolation Forest per Risk Score runtime.
- **Honeypot Applicativo [Go]:** Ambiente isolato per Tarpitting e fake data.
- **Observability Pipeline [Fluent Bit]:** Log asincroni OTel.
- **Pipeline Addestramento ML [Python]:** Addestramento batch offline.

Livello 3: Componenti Proxy (pkg/*)

- `pkg/listener``: Ingress HTTP.
- `pkg/interceptor``: Orchestratore di sicurezza.
- `pkg/injector``: Iniezione dinamica Honey-URL.
- `pkg/aiclient``: Client per inferenza IA.
- `pkg/router``: Routing traffico sano (< 2ms).

- ``pkg/telemetry``: Telemetria asincrona.

3. Stack Tecnologico & Razionale

- **Proxy**: Go (Performance, Goroutine, Modulo `httputil.ReverseProxy`)
- **ML Engine**: Isolation Forest (Unsupervised, veloce, leggero)
- **Inference API**: FastAPI (Asincrono, performance elevate)
- **Observability**: Fluent Bit (Scritto in C, ideale per edge)

4. Pipeline ML & Anti-Data Poisoning

- **Algoritmo**: Isolation Forest (non supervisionato). Calcolo score basato su `*path length*`.
- **Anti-Data Poisoning**: I log vengono filtrati (``IsPoisoned=True``) escludendo sessioni Honeypot prima dell'addestramento.
- **Inferenza**: Online via FastAPI, modello pre-caricato in memoria.

5. Casi d'Uso

1. **Navigazione Sana**: Proxy analizza -> IA conferma ($\text{Score} < 0.5$) -> Routing a backend.
2. **Bot Scraper**: Bot clicca Honey-URL -> Proxy rileva rotta esca -> Deviazione su Honeypot -> Tag ``IsPoisoned=True``.
3. **Attacco ATO**: Analisi Header/Frequenza -> IA rileva anomalia ($\text{Score} > 0.95$) -> Tarpitting (30s) -> Messaggio errore.
4. **Pipeline**: Job notturno -> Filtra log puliti -> Addestra IA -> Push modello produzione.

6. Metriche di Validazione

- **Performance**: Latenza routing $< 2\text{ms}$.
- **Sicurezza**: Falsi positivi (FP) target $\sim 0\%$.
- **Efficacia Deception**: `*Attacker Retention Time*` nell'Honeypot.
- **ML**: F1-Score su dataset sbilanciato.

